Lab 3A: Phishing Simulation and Quantitative Risk Analysis

Executive briefing and supporting analysis for GlobalTech Inc.

Item	Detail
Prepared by	Chioma Ameh | Registration number C11/26/CGRCE/17567
Course / lab	GRC103, Risk Assessment and Management Techniques | Lab 3A
Role	Lead GRC Analyst, reporting to the CISO
Date	2 November 2026
Supporting file	Lab3A_Phishing_Risk_Workbook.xlsx (all calculations with visible formulas)

1. Executive briefing

To: CISO and executive leadership | **From:** Lead GRC Analyst | **Subject:** Phishing exposure and control investment

I analysed the three phishing simulation campaigns run at GlobalTech. The clearest result is that the IT password-reset lure (Campaign B) worked best for the attacker: **30.0%** of recipients submitted credentials, against 18.0% for the HR lure and 15.0% for the executive lure. Statistical tests show B is significantly higher than both of the others ($p = 0.022$ and 0.008), while A and C cannot be told apart ($p = 0.59$). If B's rate held across all 2,000 employees, about **600 accounts** would be compromised.

The brief's own financial model turns those accounts into 150 separate $4.35 million breaches, a loss of $652,500,000 a year. I do not think that is defensible, because it treats every compromised account as an independent breach without any justification. My base case assumes one phishing attack a year with a 25% chance of a major breach, which gives an annualised loss of **$1,087,500**. Even at 12 attacks a year the loss is $13,050,000, so the conclusions below do not depend on the exact frequency.

Key findings

- Executives were the most willing to engage (90.0% opened, 75.0% clicked), but only 20.0% of those who clicked went on to submit credentials, the lowest conversion of the three.
- In my base case, MFA has the best return: $1,086,413 of annual risk removed for $90,000, an ROI of 1,107% and a payback of about 1.0 month. Training (553%) and email filtering (335%) follow. The same ranking holds under the brief's model.
- The full $490,000 programme needs to remove only 45.1% of the base-case loss to break even (about 0.11 breaches' worth of cost).

Recommended actions

- Deploy MFA across the organisation first, starting with the IT and HR groups.
- Run anti-phishing training for everyone, with extra modules for HR (bonus-themed lures) and executives (urgent-request lures).
- Add email filtering, but treat its 20% effect as an assumption until measured.
- Repeat the simulation with comparable groups and larger samples before setting targets, because the three groups differed in size and role.

These figures rest on scenario assumptions (breach cost, effectiveness percentages and attack frequency). Section 7 lists them and the main limitations.

2. Phase 1: Campaign rates and conversions

Rates use emails sent as the denominator. Conversion rates use the previous step in the attack as the denominator, so they answer a different question: of the people who got this far, how many went further?

Campaign	Group	Sent	Open rate	Click rate	Credential rate	Data entry rate	Open to click	Click to credential
A	100 HR employees	100	82.0%	47.0%	18.0%	5.0%	57.3%	38.3%
B	250 IT-related employees	250	80.0%	60.0%	30.0%	10.0%	75.0%	50.0%
C	80 executives and assistants	80	90.0%	75.0%	15.0%	10.0%	83.3%	20.0%
All	**Pooled**	**430**	**82.3%**	**59.8%**	**24.4%**	**8.8%**	**72.6%**	**40.9%**

Campaign C has the highest open and click rates but the lowest credential rate. The executives and assistants were willing to look but less willing to type credentials. Campaign B converts half of its clickers into credential submissions.

3. Phase 2: Scaling and financial exposure

Scaling each campaign's credential rate to 2,000 employees gives the number of accounts that could be compromised. The brief then multiplies that by the 25% breach probability and the $4.35 million breach cost (Scenario A).

Campaign	Credential rate	Accounts compromised (of 2,000)	Scenario A breaches	Scenario A exposure
A: 100 HR employees	18.0%	360	90	$391,500,000
B: 250 IT-related employees	30.0%	600	150	$652,500,000
C: 80 executives and assistants	15.0%	300	75	$326,250,000

Why I do not use Scenario A as the base case. It treats 600 stolen credentials as 150 independent $4.35 million breaches and states no annual frequency. In practice a single compromise usually leads to one incident, and the instructor's briefing says accounts should not be treated as independent breaches without justification. I therefore built a second scenario:

Scenario	Assumption	Annualised loss (ALE)
A (brief)	Each compromised account is a separate breach (150 a year)	$652,500,000
B (base case)	One phishing attack a year; 25% chance it causes a major breach; $4.35M per breach	$1,087,500
B, sensitivity	2 phishing attacks a year	$2,175,000
B, sensitivity	4 phishing attacks a year	$4,350,000
B, sensitivity	12 phishing attacks a year	$13,050,000

4. Control cost-benefit analysis

Risk reduction is the annual loss multiplied by the control's effectiveness. ROI is (risk reduction - cost) / cost. Effectiveness figures are scenario assumptions supplied by the brief, not verified benchmarks.

Control	Cost	Effect.	A: risk reduction	A: ROI	B: risk reduction	B: ROI	B payback (months)
MFA	$90,000	99.9%	$651,847,500	724,175%	$1,086,413	1,107%	1.0
Enhanced training	$100,000	60%	$391,500,000	391,400%	$652,500	553%	1.8
Email filtering	$50,000	20%	$130,500,000	260,900%	$217,500	335%	2.8
Full programme (brief)	$490,000	90%	$587,250,000	119,747%	$978,750	100%	6.0

Under both scenarios the order is the same: MFA, then training, then email filtering. That agreement matters more than the absolute figures, which depend heavily on the breach assumptions.

Bonus: break-even. The $490,000 programme pays for itself if it prevents 0.1126 breaches ($490,000 / $4,350,000). In my base case that means removing 45.1% of the expected annual loss; under the brief's model, only 0.075%.

5. Phase 3: Risk matrix and statistical analysis

Campaign	Group	Cred. rate	Accounts (scaled)	Scenario A exposure	Rating	Priority	Recommended action
A	100 HR employees	18.0%	360	$391,500,000	Medium	2	Targeted training for HR (bonus-themed lures)
B	250 IT-related employees	30.0%	600	$652,500,000	High	1	MFA across the organisation first
C	80 executives and assistants	15.0%	300	$326,250,000	Medium	3	Executive-specific training plus MFA

Ratings use credential-rate bands (High at 25% or more, Medium at 10% or more). Priority ranks the campaigns by the number of accounts that would be compromised. Dollar exposure follows the brief's per-account method and is shown for comparison only. Executives are a small, high-value group, so Campaign C deserves attention beyond what its rate suggests.

95% confidence intervals for the credential rate: $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$

Campaign	n	Rate	Margin of error	95% interval	Width
A	100	18.0%	± 7.5%	10.5% to 25.5%	15.1%
B	250	30.0%	± 5.7%	24.3% to 35.7%	11.4%
C	80	15.0%	± 7.8%	7.2% to 22.8%	15.6%

Two-proportion tests (is the difference more than chance?)

Comparison	z	p-value	Significant at 95%?
B vs A	2.30	0.0217	Yes

Comparison	z	p-value	Significant at 95%?
B vs C	2.65	0.0080	Yes
A vs C	0.54	0.5915	No

The intervals for A and B overlap slightly, but the direct test shows B is still significantly higher than A. A and C are statistically indistinguishable.

Sampling limitations. The three campaigns targeted different groups (HR, IT-related staff, executives and assistants) and used samples of 80 to 250. None was a random sample of all 2,000 employees, so the rates describe those groups, not the whole company. Smaller samples give wider intervals (Campaign C's is the widest). Scaling the executive rate to everyone is therefore the weakest step in the analysis.

6. Corrections to the brief

I checked every worked figure in the brief. Items marked Corrected differ from what the brief's own formulas give.

Item	Brief says	Recalculated	Status
Campaign A exposure ($)	$156,600,000	$391,500,000	Corrected
Campaign C exposure ($)	$104,400,000	$326,250,000	Corrected
Campaign B exposure ($)	$652,500,000	$652,500,000	Confirmed
MFA ROI	724,175%	724,175%	Confirmed
Training ROI	391,400%	391,400%	Confirmed
Email filtering ROI	260,800%	260,900%	Corrected
Total risk reduction at 90% ($)	$587,500,000	$587,250,000	Corrected
Overall credential theft rate	22.10%	24.42%	Corrected

Statements that are unsupported or cannot be reproduced

Statement	Problem	Treatment
93.75% probability of major breach	150 is an expected count, not a probability, and no working is given	Not reproduced
Industry-average column	No source is given	Not used; breach cost and effectiveness are scenario assumptions
Training: new click-through rate 30% × (1 - 0.60) = 12%	30% is Campaign B's credential rate; its click-through rate is 60%	Relabelled; 60% applied to credential theft
600 accounts become 150 separate breaches	Each account treated as an independent breach without justification	Scenario A only; Scenario B is the base case
Annual loss of $652.5M	No annual occurrence assumption is stated	Stated explicitly, with a sensitivity table
Email filtering effectiveness	The brief implies 20%; the study guide cites 70 to 90% of malicious emails blocked	Brief's implied 20% used and flagged

7. Assumptions and limitations

- Breach cost ($4.35M), the 25% breach probability and the control effectiveness percentages are scenario assumptions from the brief, not verified benchmarks.
- Scenario B assumes one phishing attack a year. This is my assumption, and the sensitivity table shows what happens at 2, 4 and 12.
- Each control is evaluated on its own. I did not add or combine reductions, and the brief's 90% reduction for the full programme is shown as given.
- The campaigns used different target groups and sample sizes, so comparisons between them are indicative, not exact.
- The $85,000 average salary is not needed by any calculation, so it is not used.
- The model excludes indirect costs such as reputation damage and regulatory action beyond the stated breach cost.

8. Declaration of AI assistance

I used Claude, an AI assistant from Anthropic, throughout this lab. It explained the formulas, checked my work against the brief, found the errors listed in Section 6, helped build the workbook and helped draft this report. I reviewed the results and spot-checked the key figures in the workbook myself. Because AI can make mistakes, every number in this report comes from the workbook formulas, which were recalculated and compared with hand calculations.

Appendix: Files

File	Content
README.md	Overview and repository guide
spreadsheet/Lab3A_Phishing_Risk_Workbook.xlsx	All calculations with visible formulas (8 sheets)
docs/Lab3A_Phishing_Risk_Report.docx	This report